

# Intelligent Data Privacy & Compliance Copilot

## Product Requirements & Technical Specification

---

### 1. Overview

#### 1.1 Objective

Build an AI-powered system that:

- Automates **data privacy risk assessment**
  - Predicts compliance risks
  - Provides **explainable recommendations**
  - Assists auditors with **traceable insights** - *Serves 40k requests per 5 minutes.*
- 

#### 1.2 Key Capabilities

- Automated DPA (Data Processing Activity) analysis
  - Risk scoring & classification
  - Regulatory compliance validation
  - AI-generated audit explanations
  - Agent-driven orchestration
- 

#### 1.3 Stakeholders

- Compliance Officers
- Legal Teams
- Data Protection Officers (DPOs)
- Internal Audit Teams
- Engineering / Data Governance Teams

---

## 2. Functional Requirements

### 2.1 Data Ingestion

- Accept structured & unstructured inputs:
  - DPA forms
  - Privacy policies
  - Contracts
  - Logs (access, transfer, storage)

#### Requirements:

- Support batch + real-time ingestion
  - API + file upload interface
- 

### 2.2 NLP-Based Document Processing

- Extract:
  - Personal data types (PII, PHI, financial)
  - Processing purpose
  - Data transfer details

#### Model:

- BERT
- 

### 2.3 Risk Classification Engine

- Classify risk:
  - Low / Medium / High

#### Model:

- Random Forest

#### Features:

- Data sensitivity
  - Volume of records
  - Cross-border transfer
  - Historical violations
- 

## 2.4 Risk Prediction Engine

- Predict future compliance risks

### Model:

- LSTM

### Outputs:

- Risk trend (increasing / stable / decreasing)
  - Time-based forecasts
- 

## 2.5 Regulatory Reasoning (RAG)

- Retrieve:
    - Internal policies
    - Regulations (GDPR, HIPAA, etc.)
  - Generate:
    - Contextual explanations
- 

## 2.6 Agentic Orchestration

Agents coordinate the workflow:

- Ingestion Agent
- NLP Agent
- Risk Agent
- Compliance Agent
- Explanation Agent
- Audit Agent

### Framework options:

- LangChain
  - CrewAI
- 

## 2.7 Reporting & Dashboard

- Risk dashboards
  - Audit logs
  - Downloadable compliance reports
- 

## 3. Non-Functional Requirements

### 3.1 Performance

- Response time: < 3 seconds (API)
- Batch processing support

### 3.2 Scalability

- Handle millions of records
- Horizontal scaling (microservices)

### 3.3 Security

- Data encryption (at rest + in transit)
- Role-based access control (RBAC)

### 3.4 Compliance

- GDPR-ready architecture
- Audit logging mandatory

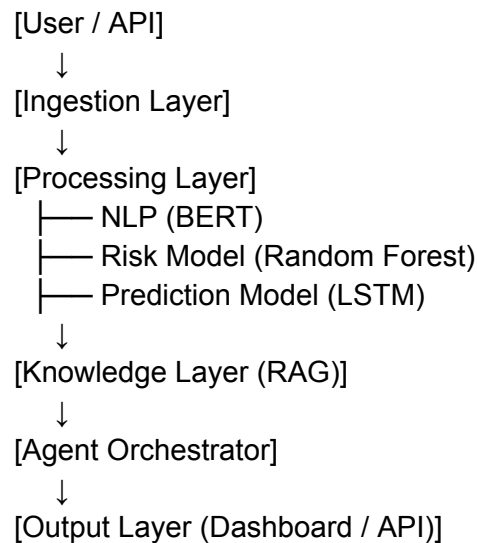
### 3.5 Explainability

- All AI outputs must include reasoning

---

## 4. 🏗️ System Architecture

### 4.1 High-Level Components



---

### 4.2 Data Flow

1. Input received (DPA / document)
  2. NLP extracts structured data
  3. Risk classification executed
  4. Time-series prediction applied
  5. RAG retrieves relevant regulations
  6. Agents generate explanation & recommendation
  7. Output stored + displayed
- 

## 5. 🧠 Model Specifications

### 5.1 BERT (NLP Engine)

- Task: Named Entity Recognition + Classification
- Input: Documents (PDF, text)

- Output:
    - Entities (PII, location, purpose)
- 

## 5.2 Random Forest (Risk Classification)

- Input features:
    - Data type
    - Geography
    - Access frequency
    - Encryption status
  - Output:
    - Risk label + probability
- 

## 5.3 LSTM (Time-Series Prediction)

- Input:
    - Historical risk scores
  - Output:
    - Future risk trend
- 

## 5.4 RAG Pipeline

- Retriever: Vector DB (FAISS / Pinecone)
- Generator: LLM

### Sources:

- Regulatory docs
  - Internal compliance policies
- 

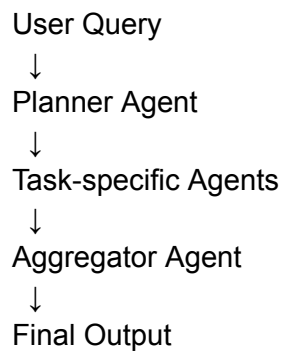
# 6. Agent Design

## 6.1 Agent Responsibilities

| Agent             | Responsibility              |
|-------------------|-----------------------------|
| Ingestion Agent   | Data collection             |
| NLP Agent         | Document parsing            |
| Risk Agent        | Classification + prediction |
| Compliance Agent  | Rule validation             |
| Explanation Agent | RAG-based reasoning         |
| Audit Agent       | Reporting                   |

---

## 6.2 Agent Workflow



## 7. APIs (Sample Design)

### POST /analyze-dpa

Input:

```
{  
  "document": "...",  
  "metadata": {...}  
}
```

Output:

```
{  
  "risk_level": "HIGH",
```

```
"confidence": 0.87,  
"prediction": "Increasing risk",  
"explanation": "...",  
"recommendations": [...]  
}
```

---

## GET /report/{id}

- Returns audit report
- 

## 8. Data Storage

- Structured Data → PostgreSQL
  - Documents → Object Storage (S3)
  - Embeddings → Vector DB
- 

## 9. Deployment Architecture

- Microservices (Docker + Kubernetes)
  - CI/CD pipeline
  - Cloud: AWS / Azure / GCP
- 

## 10. Evaluation Metrics

### Model Metrics

- BERT: F1-score
- Random Forest: Accuracy, ROC-AUC
- LSTM: RMSE

### System Metrics

- Latency
  - Throughput
  - Explainability score (human validation)
- 

## 11. Risks & Mitigation

| Risk                     | Mitigation                    |
|--------------------------|-------------------------------|
| Incorrect classification | Human-in-loop validation      |
| Regulatory updates       | Continuous ingestion pipeline |
| Model drift              | Periodic retraining           |

---

## 12. Future Enhancements

- Real-time monitoring
  - Chat-based compliance assistant
  - Integration with enterprise tools
  - Multi-language support
- 

## Summary

This system combines:

- ML (LSTM, Random Forest)
- NLP (BERT)
- LLM + RAG
- Agentic AI

To deliver a **scalable, explainable, enterprise-ready compliance platform**.